

Durcissement Linux - Accès, Privilèges et Système de Fichiers

Objectifs :

- Comprendre la philosophie de gestion des droits sous Linux (Tout est fichier).
- Sécuriser drastiquement le service d'accès à distance (OpenSSH) selon l'ANSSI.
- Maîtriser la délégation de privilèges via sudo et éviter les erreurs de configuration.
- Appliquer le principe du moindre privilège par défaut via l'Umask.
- Identifier et neutraliser les risques liés aux binaires SUID/SGID.

1. La Philosophie de Sécurité Linux

Contrairement à Windows qui s'appuie sur une base de registre centralisée et des objets complexes (GPO, SAM), Linux repose sur un principe fondateur simple : **"Tout est fichier"**.

- La configuration d'un service est un fichier texte (ex: /etc/ssh/sshd_config).
- Les mots de passe sont dans un fichier texte (/etc/shadow).
- Les périphériques matériels (disques) sont représentés par des fichiers (/dev/sda).

Conséquence pour le durcissement : La sécurité d'un système Linux repose à 90% sur la gestion stricte des droits de lecture, d'écriture et d'exécution appliqués sur ces fichiers. Si les droits sont mal gérés, le système s'effondre.

2. Verrouillage des Accès Distants (OpenSSH)

Le service SSH (sshd) est la porte d'entrée principale des administrateurs, mais aussi des attaquants. Sa configuration par défaut est souvent trop permissive. Le fichier maître à modifier est /etc/ssh/sshd_config.

2.1 Interdire l'accès direct au super-administrateur (root)

L'ANSSI interdit formellement de se connecter directement en tant que root via le réseau. Un attaquant ne devrait jamais pouvoir lancer une attaque par force brute sur le compte suprême.

- **Paramètre à modifier :** PermitRootLogin no
- **La bonne pratique :** On se connecte avec un compte standard nominatif (ex: gregory), puis on élève ses privilèges temporairement via la commande sudo.

2.2 Bannir les mots de passe au profit des clés cryptographiques

Les mots de passe peuvent être devinés, volés ou interceptés. L'authentification par clé publique/privée (RSA 4096 bits ou ED25519) est insensible au *brute-force*.

- **Paramètres à modifier :**
 - PasswordAuthentication no

- PubkeyAuthentication yes

2.3 Restreindre les utilisateurs autorisés

Plutôt que de laisser n'importe quel compte système tenter de se connecter, on définit une "liste blanche" stricte.

- **Paramètre à ajouter** : AllowUsers gregory mouloud admin-sys
- **Alternative par groupe** : AllowGroups ssh-users

Rappel : Après toute modification du fichier de configuration, il faut recharger le service avec `sudo systemctl restart sshd`.

3. Gestion et Délégation des Privilèges (sudo)

Sous Linux, l'utilisateur root a un pouvoir absolu de vie ou de mort sur le système. Utiliser root au quotidien est une aberration sécuritaire.

3.1 Le rôle de Sudo

sudo (SuperUser DO) permet à un utilisateur standard d'exécuter une commande spécifique avec les droits d'un autre utilisateur (généralement root), sous réserve que l'administrateur l'y ait autorisé dans le fichier `/etc/sudoers`.

3.2 Utiliser visudo

On ne modifie **jamais** le fichier `/etc/sudoers` avec un éditeur classique (comme nano ou vim). En cas d'erreur de syntaxe, le fichier est corrompu et plus personne ne peut devenir administrateur.

- **L'outil obligatoire** : La commande `sudo visudo`. Elle ouvre le fichier, permet de l'éditer, et **vérifie la syntaxe** avant de sauvegarder.

3.3 Configurer des droits granulaires

Dans `/etc/sudoers`, on peut donner les pleins pouvoirs à un groupe d'administrateurs (ex: le groupe wheel ou sudo) :

- `%sudo ALL=(ALL:ALL) ALL`

Mais on peut aussi restreindre un utilisateur métier à une seule commande, sans lui demander de mot de passe (pratique pour l'audit ou les scripts) :

- `auditscan ALL=(ALL) NOPASSWD: /usr/bin/apt-get changelog *`

4. Système de Fichiers : L'Umask (Recommandation ANSSI)

Lorsqu'un utilisateur ou un service crée un nouveau fichier ou dossier, Linux lui attribue des droits par défaut. L'Umask est le masque mathématique qui vient **soustraire** des droits à cette création.

- Droits maximums d'un dossier : 777 (rwx pour tout le monde)
- Droits maximums d'un fichier : 666 (rw- pour tout le monde, pas d'exécution)

4.1 L'Umask par défaut vs L'Umask ANSSI

Par défaut, beaucoup de distributions utilisent un Umask de 022.

- *Résultat* : $777 - 022 = 755$ pour les dossiers. Tout le monde peut lire le contenu !

L'ANSSI exige un Umask de **027** pour garantir le cloisonnement et le moindre privilège.

- *Le calcul avec 027* : $777 - 027 = 750$
- *Résultat métier* : Le propriétaire a tous les droits (7), son groupe a lecture/exécution (5), et le reste du monde n'a **aucun droit** (0).

4.2 Comment l'appliquer ?

Pour qu'il s'applique à tous les utilisateurs du système, on modifie le fichier de configuration globale : `/etc/login.defs` (paramètre `UMASK 027`).

5. Les Binaires SUID / SGID

C'est l'un des points d'audit les plus critiques sous Linux.

5.1 Qu'est-ce que le bit SUID ?

Normalement, quand vous lancez un programme, il s'exécute avec **vos** droits.

Le bit **SUID** (Set-user Identification) modifie cette règle : le programme s'exécute avec les droits du **propriétaire du fichier**.

Exemple légitime : La commande `/usr/bin/passwd` appartient à root et possède le bit SUID.

Quand un utilisateur standard la lance, le programme tourne temporairement en tant que root, ce qui permet à l'utilisateur de modifier son mot de passe dans le fichier hyper-protégé `/etc/shadow`.

5.2 L'exploitation par les attaquants (GTFOBins)

Si un administrateur configure par erreur le bit SUID sur un outil classique (ex: `find`, `vim`, `python`, `bash`) pour faciliter une tâche, un attaquant va l'utiliser pour ouvrir un terminal en tant que root. C'est l'élévation de privilèges instantanée.

5.3 L'audit continu

L'administrateur doit vérifier régulièrement qu'aucun binaire illégitime ne possède ce bit SUID.

- **Commande de recherche des fichiers SUID :**
`find / -perm -4000 -type f -exec ls -la {} + 2>/dev/null`

Si l'audit remonte des exécutable suspects, il faut retirer le bit SUID immédiatement avec `chmod u-s /chemin/vers/fichier`.